

MOMENTO

Security Vulnerability Analysis

System Requirements Specification – Risk Assessment

Riga, 2026

Introduction

This document identifies and analyzes security vulnerabilities that could theoretically arise in the Momento mobile application, a location-based digital time capsule platform. The analysis is based on application's key technology stack: React Native (frontend), Java/Spring Boot (backend), PostgreSQL/PostGIS (database), Firebase Authentication, AWS S3/Firebase Storage, Firebase Cloud Messaging (FCM), and Google Maps API.

Each vulnerability is assessed by type, affected component, potential business and technical impact, and concrete prevention measures. Vulnerabilities are mapped to the OWASP Top 10 where applicable.

Vulnerability Analysis

1. GPS Spoofing / Location Forgery

Vulnerability	GPS Spoofing / Location Forgery
Type	Location Integrity Attack
Affected Component	GPS / Location Services, Backend API
Potential Impact	• Attackers forge GPS coordinates to "discover" capsules without physically visiting locations • Undermines the core game mechanic and devalues real discoveries • Points system can be abused to gain unfair advantages (cheating/farming) • Creators' capsules may be unfairly unlocked and their expiry extended by illegitimate discoverers
Prevention Measures	• Cross-validate location data server-side using multiple signals (Wi-Fi triangulation, cell tower data) where available • Implement anomaly detection: flag users who "discover" capsules at impossible speeds or locations • Use Android SafetyNet / iOS DeviceCheck to detect rooted/jailbroken devices running GPS mock apps • Apply rate-limiting on discovery events per user per time window

- Log and audit discovery patterns for statistical outliers

2. Insecure Direct Object Reference (IDOR) on Capsule Content

Vulnerability	Insecure Direct Object Reference (IDOR) on Capsule Content
Type	Broken Access Control (OWASP A01)
Affected Component	Backend API (Spring Boot), Cloud Storage (AWS S3 / Firebase Storage)
Potential Impact	• Unauthorized users access capsule media (photos, voice notes) without physically visiting the location • Media URLs leaked via API responses could allow anyone to fetch content, bypassing the discovery requirement • Private or sensitive user-generated content is exposed – a major privacy breach • Complete defeat of the application's core security premise
Prevention Measures	• Never expose direct media URLs in API responses; generate short-lived signed URLs (e.g., AWS S3 pre-signed URLs, max 15 minutes) only after server-side proximity validation • Enforce access control checks in the backend for every capsule content request, verifying the user's discovery record • Store media in private S3/Firebase buckets – no public-read ACL • Implement comprehensive authorization tests covering all capsule API endpoints

3. Broken Authentication — Session Token Theft / JWT Vulnerabilities

Vulnerability	Broken Authentication – Session Token Theft / JWT Vulnerabilities
Type	Broken Authentication (OWASP A07)
Affected Component	Firebase Authentication, Backend API, Mobile Client
Potential Impact	• Stolen session tokens allow full account takeover – attacker acts as the victim user • Attacker can drop/delete capsules, accumulate points, and access all personal data on behalf of the victim • If JWTs are misconfigured (e.g., 'none' algorithm accepted), backend authorization is bypassed entirely • Exposure of user location history and personal media content
Prevention Measures	• Always validate JWT signatures server-side using Firebase's public key endpoint; never accept unsigned or 'alg: none' tokens • Set short JWT expiry times (e.g., 1 hour) with mandatory refresh token rotation • Transmit tokens exclusively over HTTPS (already specified in NFR #26) – enforce HSTS headers • Implement token revocation on logout and password change • Store tokens in secure storage (iOS Keychain / Android Keystore), never in plain SharedPreferences or localStorage

4. Excessive Location Data Retention & Privacy Leakage

Vulnerability	Excessive Location Data Retention & Privacy Leakage
Type	Sensitive Data Exposure / Privacy Violation (OWASP A02, GDPR)
Affected Component	PostgreSQL/PostGIS Database, Backend API
Potential Impact	• Continuous GPS tracking stored beyond necessity reveals precise user movement patterns and daily routines • A database breach exposes sensitive location history for all users – severe GDPR violation with significant legal and financial penalties • Location data combined with user profiles enables stalking or physical harm to users • Reputational damage and regulatory fines (GDPR Article 83 fines up to €20M or 4% of annual turnover)
Prevention Measures	• Store only the GPS coordinates of dropped capsules and proximity check results – never log continuous user tracking data • Apply data minimization: use geohashing (e.g., H3 or S2) to store approximate zone rather than precise coordinates where possible • Encrypt all location data at rest using AES-256; use column-level encryption in PostgreSQL for sensitive fields

	• Define and enforce data retention policies: purge location-associated data on account deletion • Conduct a GDPR Data Protection Impact Assessment (DPIA) before launch
--	---

5. Mass Assignment / Unvalidated Input on Capsule Creation

Vulnerability	Mass Assignment / Unvalidated Input on Capsule Creation
Type	Injection / Mass Assignment (OWASP A03, A04)
Affected Component	Backend API (Spring Boot), PostgreSQL Database
Potential Impact	• Malicious users inject crafted payloads to manipulate capsule metadata (e.g., override creator ID, set negative expiry, bypass the 1-per-24h restriction) • An attacker could claim ownership of other users' capsules or create capsules at any arbitrary coordinates without physical presence • SQL injection through unvalidated GPS or text fields could expose or corrupt the entire database • NoSQL-style injections in media metadata fields could lead to data loss or unauthorized data modification
Prevention Measures	• Use DTOs (Data Transfer Objects) with strict field whitelisting – never bind HTTP request bodies directly to database entities • Apply server-side validation for all inputs: GPS coordinate ranges, media MIME types, content size limits • Use parameterized queries / JPA/Hibernate ORM exclusively – never concatenate user input into SQL strings • Validate and sanitize all text content for XSS (especially text capsule content rendered in the app) • Enforce the 24-hour duplicate coordinate rule at the database level with a unique constraint, not only in application logic

6. Push Notification Content Leakage via FCM

Vulnerability	Push Notification Content Leakage via FCM
Type	Sensitive Data in Push Notifications (Information Disclosure)
Affected Component	Firebase Cloud Messaging (FCM), Mobile Client
Potential Impact	• Push notifications containing capsule content or precise location details visible on lock screens expose data to anyone with physical access to the device • FCM tokens not properly managed could allow notification hijacking – sending spoofed notifications to users

	• Notification payloads intercepted in transit (if not properly secured) could reveal user activity patterns • Attackers who obtain FCM server keys from leaked source code could send arbitrary notifications to all users (phishing/social engineering)
Prevention Measures	• Send only opaque notification payloads (e.g., 'You have a new discovery!') – never include capsule content, coordinates, or user data in push notification bodies • Store FCM server keys exclusively in backend environment variables / secret managers (AWS Secrets Manager, Google Secret Manager) – never in the mobile app bundle or source code • Rotate FCM server keys periodically and immediately if a breach is suspected • Implement FCM token refresh logic and invalidate stale tokens on logout

Summary

The six vulnerabilities identified above represent the most critical risk areas for the Momento. The most severe risks are GPS spoofing (which undermines the app's core value proposition), IDOR on capsule media (which bypasses the fundamental discovery mechanic), and excessive location data retention (which poses GDPR and safety risks).

Handling these vulnerabilities should be treated as a major requirement before any public launch. The prevention measures described are keeping up with industry standards (OWASP, GDPR, Firebase security guidelines) and are achievable within the specified technology stack without significant architectural changes.

Risk Priority Matrix

#	Vulnerability	Type	Severity	Priority
1	GPS Spoofing	Location Integrity	High	P1 – Critical
2	IDOR on Capsule Media	Access Control	Critical	P1 – Critical
3	Session Token Theft / JWT	Authentication	Critical	P1 – Critical
4	Location Data Retention	Privacy / GDPR	High	P1 – Critical
5	Mass Assignment / Injection	Input Validation	High	P2 – High
6	FCM Notification Leakage	Info Disclosure	Medium	P2 – High

Kanan Badalov **231ADB226**
Tural Velizade **231ADB156**
Tunjay Huseynov **231ADB228**
Mahammad Aliyev **231ADB137**
Aykhan Manafov **231ADB136**